

SAST LAB ACTIVITY

Analysis of vulnerable repositories with SAST and SCA

REPOSITORIES:

- Django
- Gomoku

TOOLS:

- SonarCloud
- Trivy scanner

Django

- **Django.** A highly structured, widely adopted open-source Python web framework.
- Frequently utilized in enterprise development to handle **complex database interactions** and **rapid backend application deployment**.
- Created by web developers **Adrian Holovaty** and **Simon Willison** in the **autumn of 2003**
- Few dependencies: **sqlparse**, **asgiref**, **pytz**
- Some known vulnerabilities in **v3.2.13: CVE-2022-34265** (SQL Injection within ORM analytical lookups) and **CVE-2021-35042** (SQL Injection risks in QuerySet filters)

DJANGO V3.2.13 (SAST)

Security

1.1k Open Issues

E

Reliability

274 Open Issues

E

Maintainability

2.5k Open Issues

A

HIGH SEVERITY SECURITY ISSUE EXAMPLE

```
313 floria...
314 paul@m...
315
316
317 Alternate PBKDF2 hasher which uses SHA1, the default PRF
318 recommended by PKCS #5. This is compatible with other
319 implementations of PBKDF2, such as openssl's
320 PKCS5_PBKDF2_HMAC_SHA1().
321
322 algorithm = "pbkdf2_sha1"
323 digest = hashlib.sha1
```

Make sure that hashing data is safe here.

HIGH SEVERITY SECURITY ISSUE EXAMPLE

- SonarCloud flagged multiple instances of **hashlib.sha1** and **pbkdf2_sha1** with the warning: "Make sure that hashing data is safe here."
- Automated SAST rule matching detects the SHA-1 signature, which is mathematically **deprecated** due to collision risks.
- Code inspection reveals this is the **PBKDF2SHA1PasswordHasher class**, maintained purely for **legacy database migration** and **backward compatibility**.
- Framework defaults prioritize **SHA-256** and **Argon2** for new secret creation; the flagged code is **never executed unless explicitly declared** for legacy support.

DJANGO V3.2.13 – SAMPLE CVE

CVE-2022-34265 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

An issue was discovered in Django 3.2 before 3.2.14 and 4.0 before 4.0.6. The Trunc() and Extract() database functions are subject to SQL injection if untrusted data is used as a kind/lookup_name value. Applications that constrain the lookup name and kind choice to a known safe list are unaffected.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: **9.8 CRITICAL**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

- Fixed in **v3.2.14**
- SQL injection in **Trunc()** and **Extract()** database functions.
- Not spotted by SonarQube (**False Negative**), probably due to Framework Abstraction.

- NVD record: <https://nvd.nist.gov/vuln/detail/cve-2022-34265>
- PoC: <https://github.com/aeyesec/CVE-2022-34265>

DJANGO V3.2.13 (SCA)

```
D:\Programmes\trivy_0.69.0_windows-64bit>trivy fs D:\Repositories\django\django
2026-07-07T16:50:42+02:00      INFO    [vulndb] Need to update DB
2026-07-07T16:50:42+02:00      INFO    [vulndb] Downloading vulnerability DB...
2026-07-07T16:50:42+02:00      INFO    [vulndb] Downloading artifact...      repo="mirror.goc
99.41 MiB / 99.41 MiB [-----]
2026-07-07T16:51:18+02:00      INFO    [vulndb] Artifact successfully downloaded      repo="m
2026-07-07T16:51:18+02:00      INFO    [vuln] Vulnerability scanning is enabled
2026-07-07T16:51:18+02:00      INFO    [secret] Secret scanning is enabled
2026-07-07T16:51:18+02:00      INFO    [secret] If your scanning is slow, please try '--scanne
2026-07-07T16:51:18+02:00      INFO    [secret] Please see https://trivy.dev/docs/v0.69/guide/
2026-07-07T16:52:33+02:00      WARN    [pip] Unable to find python 'site-packages' directory.
not found"
2026-07-07T16:52:33+02:00      INFO    Number of language-specific files      num=1
2026-07-07T16:52:33+02:00      INFO    [python-pkg] Detecting vulnerabilities...
```

Report Summary

Target	Type	Vulnerabilities	Secrets
tests/app_loading/eggs/brokenapp.egg	python-pkg	0	-
tests/app_loading/eggs/modelapp.egg	python-pkg	0	-
tests/app_loading/eggs/nomodelapp.egg	python-pkg	0	-
tests/app_loading/eggs/omelet.egg	python-pkg	0	-
tests/template_tests/eggs/tagsegg.egg	python-pkg	0	-
tests/user_commands/eggs/basic.egg	python-pkg	0	-
tests/utils_tests/eggs/test_egg.egg	python-pkg	0	-

Legend:

- '-': Not scanned
- '0': Clean (no security findings detected)

- Although django have some dependencies, Trivy doesn't seem to pickup on them.
- Probably because django dependencies are in setup.cfg file.
- Executed the following command in the repo to have a .txt file with the dependencies.
- `pip freeze > requirements.txt`
- Results in the next slides

DJANGO V3.2.13 (SCA)

```
D:\Programmes\trivy_0.69.0_windows-64bit>trivy fs D:\Repositories\django\django
2026-07-06T19:35:12+02:00      INFO    [vuln] Vulnerability scanning is enabled
2026-07-06T19:35:12+02:00      INFO    [secret] Secret scanning is enabled
2026-07-06T19:35:12+02:00      INFO    [secret] If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2026-07-06T19:35:12+02:00      INFO    [secret] Please see https://trivy.dev/docs/v0.69/guide/scanner/secret#recommendation for faster secret detection
2026-07-06T19:36:19+02:00      WARN    [pip] Unable to find python `site-packages` directory. License detection is skipped.      err="site-packages directory not found"
2026-07-06T19:36:19+02:00      INFO    Number of language-specific files      num=2
2026-07-06T19:36:19+02:00      INFO    [pip] Detecting vulnerabilities...
2026-07-06T19:36:19+02:00      INFO    [python-pkg] Detecting vulnerabilities...
```

Report Summary

Target	Type	Vulnerabilities	Secrets
tests/app_loading/eggs/brokenapp.egg	python-pkg	0	-
tests/app_loading/eggs/modelapp.egg	python-pkg	0	-
tests/app_loading/eggs/nomodelapp.egg	python-pkg	0	-
tests/app_loading/eggs/omelet.egg	python-pkg	0	-
tests/template_tests/eggs/tagsegg.egg	python-pkg	0	-
tests/user_commands/eggs/basic.egg	python-pkg	0	-
tests/utils_tests/eggs/test_egg.egg	python-pkg	0	-
requirements.txt	pip	53	-

Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)

DJANGO V3.2.13 (SCA)

requirements.txt (pip)

=====

Total: 53 (UNKNOWN: 0, LOW: 5, MEDIUM: 21, HIGH: 24, CRITICAL: 3)

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
Flask	CVE-2026-27205	LOW	fixed	3.1.2	3.1.3	flask: Flask: Information disclosure via improper caching of session data https://avd.aquasec.com/nvd/cve-2026-27205
GitPython	CVE-2026-42215	HIGH		3.1.46	3.1.47	GitPython is a python library used to interact with Git repositories. ... https://avd.aquasec.com/nvd/cve-2026-42215
	CVE-2026-42284					GitPython is a python library used to interact with Git repositories. ... https://avd.aquasec.com/nvd/cve-2026-42284
	CVE-2026-44243				3.1.48	GitPython: GitPython: Arbitrary file write via crafted reference paths https://avd.aquasec.com/nvd/cve-2026-44243
	CVE-2026-44244				3.1.49	GitPython is a python library used to interact with Git repositories. ... https://avd.aquasec.com/nvd/cve-2026-44244
	GHSA-mv93-w799-cj2w				3.1.50	GitPython: Newline injection in config_writer() section parameter bypasses CVE-2026-42215 patch, enabling RCE... https://github.com/advisories/GHSA-mv93-w799-cj2w
Mako	CVE-2026-41205			1.3.10	1.3.11	mako: Mako: Information disclosure via path traversal vulnerability https://avd.aquasec.com/nvd/cve-2026-41205
	CVE-2026-44307				1.3.12	mako: Mako: Information disclosure via directory traversal https://avd.aquasec.com/nvd/cve-2026-44307
Pygments	CVE-2026-4539	LOW		2.19.2	2.20.0	pygments: Pygments: Denial of Service via inefficient regular expression processing in AdlLexer... https://avd.aquasec.com/nvd/cve-2026-4539

DJANGO V3.2.13 (SCA)

mistune	CVE-2026-33079	HIGH		3.2.0	3.2.1	mistune: Mistune: Regular Expression Denial of Service (ReDoS) via crafted Markdown input... https://avd.aquasec.com/nvd/cve-2026-33079
	CVE-2026-44708	MEDIUM	affected			python-mistune: Mistune: Cross-Site Scripting via improper HTML escaping in math plugin https://avd.aquasec.com/nvd/cve-2026-44708
	CVE-2026-44896		fixed		3.2.1	mistune: Mistune: Cross-Site Scripting (XSS) via unescaped HTML attributes https://avd.aquasec.com/nvd/cve-2026-44896
	CVE-2026-44897					mistune: Mistune: Cross-site scripting (XSS) via improper sanitization of HTML heading ID... https://avd.aquasec.com/nvd/cve-2026-44897
	CVE-2026-44898					mistune: Mistune: Arbitrary code execution via HTML injection in table of contents... https://avd.aquasec.com/nvd/cve-2026-44898
	CVE-2026-44899					python-mistune: Mistune: Information disclosure via CSS injection in Image directive plugin https://avd.aquasec.com/nvd/cve-2026-44899
mlflow	CVE-2026-0545	CRITICAL	affected	3.9.0		mlflow/mlflow: mlflow/mlflow: Unauthenticated remote code execution via unprotected job endpoints https://avd.aquasec.com/nvd/cve-2026-0545
	CVE-2026-2611	HIGH	fixed		3.10.0	mlflow: MLflow: Arbitrary Code Execution via Improper Origin Validation https://avd.aquasec.com/nvd/cve-2026-2611
	CVE-2026-2651				3.11.0rc1	github.com/mlflow/mlflow: MLflow: Arbitrary code execution via unauthorized multipart upload access https://avd.aquasec.com/nvd/cve-2026-2651
	CVE-2026-2614				3.10.0	mlflow: mlflow: Arbitrary file read via bypassed source path validation https://avd.aquasec.com/nvd/cve-2026-2614
	CVE-2026-2652				3.11.0	MLflow: unauthenticated access to certain FastAPI routes https://avd.aquasec.com/nvd/cve-2026-2652
	CVE-2026-4137					MLFlow Creates a Temporary File With Insecure Permissions

Gomoku

- My personal repository
- Written in Java
- Gomoku is a classic two-player board game implemented in Java for the command line.
- Few dependencies:
 - Maven for building
 - Mockito and jUnit for testing

OVERVIEW (SAST)

Last analysis: 02/02/2026, 10:23 • 540 Lines of Code • Java, XML

0	0	47	100%	0.0%
Security	Reliability	Maintainability	Hotspots Reviewed	Duplications

- No security problem identified
- No dependency issue identified
- As expected from a small and simple project it is relatively “safe

OVERVIEW (SCA)

```
D:\Programmes\trivy_0.69.0_windows-64bit>trivy repo https://github.com/AbdelrahmanAlaaeldin/Gomoku
2026-02-02T14:40:16+01:00      INFO      [vulndb] Need to update DB
2026-02-02T14:40:16+01:00      INFO      [vulndb] Downloading vulnerability DB...
2026-02-02T14:40:16+01:00      INFO      [vulndb] Downloading artifact...      repo="mirror.gcr.io/aquasec/trivy-db:2"
83.74 MiB / 83.74 MiB [-----] 100.00% 4.28 MiB p/s 20s
2026-02-02T14:40:36+01:00      INFO      [vulndb] Artifact successfully downloaded      repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-02-02T14:40:36+01:00      INFO      [vuln] Vulnerability scanning is enabled
2026-02-02T14:40:36+01:00      INFO      [secret] Secret scanning is enabled
2026-02-02T14:40:36+01:00      INFO      [secret] If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2026-02-02T14:40:36+01:00      INFO      [secret] Please see https://trivy.dev/docs/v0.69/guide/scanner/secret#recommendation for faster secret detection
Enumerating objects: 76, done.
Counting objects: 100% (76/76), done.
Compressing objects: 100% (38/38), done.
Total 76 (delta 7), reused 64 (delta 7), pack-reused 0 (from 0)
2026-02-02T14:40:37+01:00      INFO      Number of language-specific files      num=1
2026-02-02T14:40:37+01:00      INFO      [pom] Detecting vulnerabilities...
```

Report Summary

Target	Type	Vulnerabilities	Secrets
pom.xml	pom	0	-

Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)

The background features a light gray grid pattern. A large, solid light gray rectangle is centered, serving as a backdrop for the text. In the corners, there are black geometric shapes: a square with a diagonal line in the top-left, a solid square in the top-right, a solid square in the bottom-left, and a square with a diagonal line in the bottom-right. Additionally, there are three vertical white lines on the black shapes in the top-right and bottom-left corners.

Thank You